CAMTRUST BANK

POLITIQUE DE SÉCURITÉ DU RÉSEAU INFORMATIQUE

Auteur : Njimongba Fochivé Mama Abdourahim

Binôme : Nyeyambe Hinmaka

1. Objet et champ d'application

La présente politique définit les règles à respecter pour assurer la sécurité du réseau informatique de CamTrust Bank. Elle vise à protéger les équipements, les systèmes, les données et les communications de la banque contre les accès non autorisés, les erreurs de configuration et les incidents susceptibles de perturber les activités.

Elle s'applique au siège de Yaoundé, aux agences de Douala et de Garoua, ainsi qu'à l'ensemble des équipements réseau, serveurs, postes de travail, liaisons entre agences, accès Internet, réseaux Wi-Fi et connexions à distance.

Tous les employés, administrateurs et prestataires intervenant sur le système informatique de la banque sont tenus de respecter ces règles.

2. Références et cadre légal

La politique prend notamment en compte les CIS Controls v8, les recommandations de la NSA de mars 2022 relatives à la sécurité des infrastructures réseau et celles de la CISA de février 2021 concernant les réseaux sans fil d'entreprise.

Elle tient également compte des textes camerounais cités dans le cadre de ce travail, notamment :

- La loi n° 2010/012 du 21 décembre 2010 relative à la cybersécurité et à la cybercriminalité.
- La loi n° 2024/017 du 23 décembre 2024 relative à la protection des données à caractère personnel.

Les opérations impliquant des données personnelles doivent respecter les obligations légales applicables. Aucun transfert de données vers l'étranger ne doit être réalisé sans les vérifications et autorisations nécessaires.

3. Responsabilités

Les responsabilités liées à l'application de cette politique sont réparties comme suit :

1. **Le directeur général** approuve la politique et valide les dérogations qui lui sont soumises.
2. **La Direction des systèmes d'information (DSI)** veille à son application et assure le suivi des problèmes de conformité.
3. **Le référent réseau** est responsable des équipements réseau, de leurs configurations et de la validation des changements.
4. **Les administrateurs système et réseau** appliquent les mesures de sécurité, surveillent les équipements et conservent les preuves des contrôles réalisés.
5. **Les directeurs d'agence** signalent les incidents et les problèmes d'accès constatés dans leurs agences.
6. **Les prestataires de maintenance** respectent les règles de sécurité de la banque et interviennent uniquement après autorisation.
7. **Le délégué à la protection des données** examine les questions relatives aux transferts de données personnelles lorsqu'elles relèvent de ses responsabilités.

Un contrôle de conformité est organisé chaque trimestre afin de vérifier que les règles sont effectivement appliquées.

4. Classification des informations

Les informations de CamTrust Bank sont réparties en quatre niveaux : Public, Interne, Confidentiel et Secret.

Chaque information doit être protégée en fonction de son niveau de sensibilité. Les équipements qui hébergent des informations classées Secret doivent bénéficier du niveau de protection le plus élevé prévu par la grille de classification DICP.

Les collaborateurs doivent respecter les règles de manipulation, de stockage et de transmission correspondant à chaque niveau de classification.

5. Règles de sécurité du réseau

A. Gestion des comptes et administration des équipements

1. RES-01 — Administration sécurisée des équipements

L'administration des routeurs, commutateurs, pare-feu et autres équipements réseau doit se faire exclusivement au moyen du protocole SSH. L'utilisation de Telnet, TFTP, FTP et HTTP pour administrer les équipements est interdite, car ces protocoles peuvent exposer des informations sensibles.

2. RES-02 — Utilisation de comptes individuels

Chaque administrateur doit disposer de son propre compte pour accéder aux équipements et aux serveurs. Les comptes partagés ou génériques, tels que « admin », « operator » ou « cisco », sont interdits. Un compte de secours peut être conservé pour les situations exceptionnelles, à condition qu'il soit protégé, contrôlé et utilisé uniquement lorsque cela est nécessaire.

3. RES-03 — Protection des sessions et des mots de passe

Les sessions d'administration doivent se verrouiller automatiquement après cinq minutes d'inactivité. Les mots de passe et autres secrets ne doivent pas apparaître en clair dans les fichiers de configuration. Les mécanismes de protection adaptés doivent être activés sur chaque équipement.

4. RES-08 — Séparation du réseau d'administration

L'administration des équipements doit se faire depuis un réseau de management distinct, qui n'est pas directement accessible depuis Internet. Il est interdit d'administrer un équipement depuis le réseau Wi-Fi des clients ou depuis un segment exposé au public.

5. RES-28 — Suppression des accès inutiles

Lorsqu'un employé quitte la banque ou qu'un prestataire termine sa mission, ses comptes et ses droits d'accès doivent être supprimés dans un délai maximal de 24 heures. Les comptes doivent rester individuels afin que chaque opération puisse être attribuée à son auteur.

6. RES-29 — Protection des secrets d'accès

Les mots de passe, clés SSH et communautés SNMP doivent être conservés dans le coffre de secrets prévu par la banque. Il est interdit de les laisser dans des scripts, des fichiers accessibles ou des sauvegardes non protégées. Si un incident laisse penser qu'un secret a été exposé, celui-ci doit être révoqué ou remplacé.

B. Protection des ports et organisation du réseau

7. RES-04 — Désactivation des ports inutilisés

Les ports Ethernet qui ne sont reliés à aucun équipement autorisé doivent être désactivés et placés dans le VLAN de quarantaine prévu à cet effet. Aucun port inutilisé ne doit rester actif sans justification.

8. RES-05 — Contrôle des ports et services ouverts

Tous les ports et services ouverts sur les équipements réseau et les serveurs doivent être répertoriés dans une liste des ports autorisés. Tout service qui n'est pas nécessaire ou qui ne figure pas dans cette liste doit être désactivé ou bloqué.

9. RES-06 — Segmentation du réseau

Le réseau informatique doit être organisé en plusieurs segments selon les besoins de la banque : cœur de réseau, administration, agences et accès invités. Le plan d'adressage suit le modèle 10.<site>.<VLAN>.0/24, avec le site 10 pour le siège et le site 20 pour Douala.

Toute création d'un nouveau segment ou toute modification des communications entre VLAN doit être justifiée et approuvée avant sa mise en place.

10. RES-07 — Isolement du réseau invité

Le réseau destiné aux visiteurs et aux clients doit être séparé des réseaux internes de la banque. Les utilisateurs invités ne doivent pas pouvoir accéder aux serveurs internes, aux équipements d'administration ou aux autres ressources réservées au personnel. Seule la sortie vers Internet est autorisée, conformément aux règles de filtrage définies par la banque.

11. RES-09 — Sécurisation du Wi-Fi des clients

Le Wi-Fi destiné aux clients doit utiliser un nom de réseau (SSID) et un VLAN distincts de ceux du réseau interne. Un portail d'accès doit être mis en place et le débit des connexions invitées doit être limité si nécessaire. La clé du réseau interne ne doit jamais être communiquée aux clients.

12. RES-10 — Interdiction des équipements internes sur le réseau invité

Les équipements appartenant à la banque, notamment les imprimantes, serveurs et bornes internes, ne doivent pas être raccordés au réseau invité. Tout appareil inconnu détecté sur ce réseau doit être bloqué et signalé aux administrateurs pour vérification.

C. Accès des prestataires et télétravail

13. RES-11 — Encadrement des interventions des prestataires

Toute intervention d'un prestataire doit être autorisée à l'avance au moyen d'une demande enregistrée. Le compte utilisé doit être nominatif et l'accès doit être limité à quatre heures au maximum, pendant une plage horaire ouvrée. Les comptes permanents ou partagés réservés aux prestataires sont interdits.

À la fin de l'intervention, les accès temporaires doivent être fermés et l'intervention doit être documentée.

14. RES-12 — Passage par un point d'entrée sécurisé

Les prestataires doivent accéder au réseau interne par le point d'entrée sécurisé prévu par la banque, notamment le VPN et le bastion d'administration. Il est interdit de rendre directement accessible depuis Internet un équipement interne dans le seul but de faciliter une intervention technique.

15. RES-13 — Utilisation obligatoire du VPN en télétravail

Tout collaborateur qui souhaite accéder au réseau interne depuis l'extérieur doit utiliser le VPN chiffré de l'entreprise. La solution utilisée doit être approuvée par la banque, par exemple IPsec ou OpenVPN. Les services internes ne doivent pas être directement exposés sur Internet.

16. RES-14 — Sécurité des postes utilisés à distance

Le télétravail doit se faire depuis un poste appartenant à CamTrust Bank ou enregistré et approuvé par celle-ci. Le poste doit disposer d'un disque chiffré, d'une protection de sécurité à jour et d'un verrouillage automatique. Tout poste personnel qui ne respecte pas ces exigences doit être refusé pour l'accès au réseau interne.

D. Journalisation et surveillance

17. RES-15 — Centralisation des journaux

Les équipements réseau et les serveurs doivent transmettre leurs journaux à la plateforme centrale de journalisation, située à l'adresse 10.10.10.15. La journalisation locale doit également rester activée. Il est interdit de désactiver, vider ou modifier les journaux dans le but de masquer une activité.

18. RES-16 — Conservation des journaux

Les journaux de connexion et de trafic doivent être conservés pendant dix ans, conformément à l'obligation légale mentionnée dans cette politique. Leur suppression non autorisée est interdite. Les archives doivent être protégées contre les modifications et l'accès aux journaux doit lui-même être enregistré.

19. RES-17 — Traitement des alertes de sécurité

Toute alerte concernant un échec d'authentification, une modification de configuration ou un incident affectant une interface réseau doit être examinée dans un délai maximal de 24 heures ouvrées. Le traitement doit être enregistré afin de garder une trace des vérifications et des mesures prises. Aucune alerte ne doit être supprimée sans justification.

20. RES-18 — Synchronisation des horloges

Tous les équipements et serveurs doivent synchroniser leur horloge avec les deux sources NTP internes prévues, aux adresses 10.10.10.15 et 10.10.10.16. L'heure locale d'un équipement ne doit pas être considérée comme une référence fiable sans vérification.

21. RES-19 — Contrôle des écarts horaires

La modification manuelle de la date ou de l'heure d'un équipement est interdite. Tout écart supérieur à deux secondes par rapport à la référence NTP doit être signalé à la DSI afin qu'il soit corrigé. Cette règle permet de conserver des journaux cohérents lors de l'analyse d'un incident.

E. Sauvegarde et continuité de service

22. RES-20 — Sauvegarde régulière des configurations

La configuration de chaque équipement réseau doit être sauvegardée automatiquement chaque nuit et après chaque changement validé. Les copies doivent être envoyées vers le serveur de sauvegarde de la banque, notamment celui identifié par l'adresse 10.10.10.13. La conservation d'une seule copie sur l'équipement lui-même est insuffisante.

23. RES-21 — Protection et vérification des sauvegardes

Les sauvegardes de configurations et de données doivent être chiffrées et conservées hors site. Un test de restauration doit être réalisé au moins une fois par trimestre pour vérifier que les sauvegardes peuvent réellement être utilisées en cas de panne ou d'incident. Chaque test doit être consigné dans un procès-verbal. Les sauvegardes ne doivent contenir aucun secret en clair.

F. Mises à jour et gestion des changements

24. RES-22 — Application des correctifs de sécurité

Les correctifs de sécurité critiques doivent d'abord être testés dans le laboratoire GNS3 du projet CT. Après validation, ils doivent être appliqués en production dans un délai maximal de 30 jours. L'installation directe en production d'un correctif qui n'a pas été testé est interdite.

25. RES-23 — Remplacement des équipements en fin de support

L'inventaire informatique doit préciser la date de fin de support des équipements et des logiciels. Tout actif arrivé en fin de support doit être remplacé dans un délai maximal de six mois. La banque ne doit pas déployer de versions que leur fabricant ne maintient plus.

26. RES-24 — Validation préalable des changements

Toute modification d'une configuration en production doit faire l'objet d'une demande de changement enregistrée. Cette demande doit préciser l'objectif, les impacts possibles, le plan de retour arrière et la période prévue pour l'intervention. Le référent réseau doit valider la demande avant l'exécution. Toute modification non autorisée est interdite.

27. RES-25 — Tests obligatoires avant la mise en production

Toute nouvelle configuration réseau doit être testée dans le laboratoire GNS3 du projet CT avant son déploiement. Les six contrôles de connectivité prévus dans le TP0.1 doivent être réalisés. La mise en production doit être accompagnée d'un procès-verbal de validation et de preuves datées.

G. Protection des données personnelles

28. RES-26 — Autorisation des transferts de données vers l'étranger

Tout transfert de données personnelles hors du Cameroun doit faire l'objet des validations internes et des autorisations prévues par la réglementation applicable. Aucun service cloud ou service d'assistance technique situé à l'étranger ne doit être utilisé pour traiter ces données sans validation préalable.

29. RES-27 — Sécurisation des échanges avec l'étranger

Les données personnelles transférées vers l'étranger doivent être limitées à ce qui est nécessaire et protégées pendant leur transmission par un mécanisme de chiffrement adapté. Les connexions doivent être journalisées et chaque accès depuis l'étranger doit pouvoir être rattaché à un contrat en cours et à un intervenant autorisé.

H. Contrôle de conformité

30. RES-30 — Vérification régulière de l'application des règles

La conformité à cette politique doit être vérifiée chaque trimestre à l'aide d'une grille d'audit. Chaque campagne doit contrôler au moins cinq règles et s'appuyer sur des preuves datées, comme des extraits de configuration, des journaux ou des captures d'écran. Tout écart constaté doit donner lieu à un plan d'action précisant les mesures correctives et les délais prévus.

6. Gestion des incidents de sécurité

Tout collaborateur qui constate un accès suspect, un équipement inconnu, une interruption inhabituelle du réseau ou une possible fuite de données doit le signaler rapidement à la DSI ou au responsable compétent.

Les administrateurs doivent conserver les journaux et les éléments utiles à l'analyse de l'incident. Les mesures correctives prises doivent être documentées et, lorsque cela est possible, associées à un ticket d'intervention.

Toute modification effectuée pour résoudre un incident doit également être enregistrée. Si l'urgence impose une intervention exceptionnelle, celle-ci doit être documentée et régularisée dès que possible.

7. Dérogations et révision de la politique

Une exception à cette politique ne peut être accordée que si elle est justifiée par écrit, datée, limitée dans le temps et approuvée par la direction. La demande doit préciser le risque accepté, les mesures de protection compensatoires et la date de fin de validité de la dérogation.

La politique doit être relue au moins une fois par an. Une révision peut également être nécessaire après un incident majeur, une modification importante du réseau ou une évolution de la réglementation.

Les résultats des contrôles trimestriels et les plans d'action associés doivent être présentés à la direction et conservés comme preuves du suivi de la sécurité.

Nom et fonction : Directeur général de CamTrust Bank

Date : .....

Signature : .....